

CIS Microsoft Intune for Microsoft Defender Antivirus Benchmark

v1.0.0 - 05-27-2026

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is **NEVER** acceptable to host a CIS Benchmark in **ANY** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use	1
Table of Contents	2
Overview	5
Important Usage Information	5
Key Stakeholders	5
Apply the Correct Version of a Benchmark	6
Exceptions	6
Remediation	7
Summary	7
Target Technology Details	8
Intended Audience.....	8
Consensus Guidance	9
Typographical Conventions.....	10
Recommendation Definitions.....	11
Title.....	11
Assessment Status.....	11
Automated	11
Manual.....	11
Profile	11
Description.....	11
Rationale Statement	11
Impact Statement.....	12
Audit Procedure.....	12
Remediation Procedure.....	12
Default Value.....	12
References	12
CIS Critical Security Controls® (CIS Controls®).....	12
Additional Information.....	12
Profile Definitions	13
Acknowledgements	14
Recommendations	15
1 Microsoft Defender Antivirus	15
1.1 Client Interface	15
1.2 Exclusions	15
1.3 MAPS.....	15

1.3.1 Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled' (Automated)	16
1.3.2 Ensure 'Configure the 'Block at First Sight' feature' is set to 'Enabled' (Automated)	18
1.4 Microsoft Defender Exploit Guard	20
1.5 MpEngine	20
1.6 Network Inspection System	20
1.7 Quarantine	20
1.8 Real-time Protection	20
1.8.1 Ensure 'Turn on process scanning whenever real-time protection is enabled' is set to 'Enabled' (Automated)	21
1.9 Remediation	23
1.10 Reporting	23
1.10.1 Ensure 'Configure Watson events' is set to 'Disabled' (Automated)	24
1.11 Scan	26
1.12 Security Intelligence Updates	26
1.13 Threats	26
1.14 Ensure 'Turn off routine remediation' is set to 'Disabled' (Automated)	27
2 Defender	29
2.1 Ensure 'Allow Archive Scanning' is set to 'Allowed' (Automated)	30
2.2 Ensure 'Allow Behavior Monitoring' is set to 'Allowed' (Automated)	32
2.3 Ensure 'Allow Cloud Protection' is set to 'Allowed' (Automated)	35
2.4 Ensure 'Allow Email Scanning' is set to 'Allowed' (Automated)	38
2.5 Ensure 'Allow Full Scan Removable Drive Scanning' is set to 'Allowed' (Automated)	40
2.6 Ensure 'Allow On Access Protection' is set to 'Allow' (Automated)	43
2.7 Ensure 'Allow Realtime Monitoring' is set to 'Allowed' (Automated)	45
2.8 Ensure 'Allow scanning of all downloaded files and attachments' is set to 'Allowed' (Automated)	48
2.9 Ensure 'Allow Script Scanning' is set to 'Allowed' (Automated)	50
2.10 Ensure 'ASR: Block abuse of exploited vulnerable signed drivers' is set to 'Block' (Automated)	52
2.11 Ensure 'ASR: Block Adobe Reader from creating child processes' is set to 'Block' (Automated)	55
2.12 Ensure 'ASR: Block all Office applications from creating child processes' is set to 'Audit' or higher (Automated)	58
2.13 Ensure 'ASR: Block credential stealing from the Windows local security authority subsystem' is set to 'Block' (Automated)	61
2.14 Ensure 'ASR: Block executable content from email client and webmail' is set to 'Block' (Automated)	64
2.15 Ensure 'ASR: Block executable files from running unless they meet a prevalence, age, or trusted list criterion' is set to 'Audit' or higher (Automated)	67
2.16 Ensure 'ASR: Block execution of potentially obfuscated scripts' is set to 'Audit' or higher (Automated)	70
2.17 Ensure 'ASR: Block JavaScript or VBScript from launching downloaded executable content' is set to 'Block' (Automated)	73
2.18 Ensure 'ASR: Block Office applications from creating executable content' is set to 'Block' (Automated)	76
2.19 Ensure 'ASR: Block Office applications from injecting code into other processes' is set to 'Block' (Automated)	79
2.20 Ensure 'ASR: Block Office communication application from creating child processes' is set to 'Audit' or higher (Automated)	82
2.21 Ensure 'ASR: Block persistence through WMI event subscription' is set to 'Block' (Automated)	85
2.22 Ensure 'ASR: Block process creations originating from PSEXEC and WMI commands' is set to 'Audit' or higher (Automated)	88
2.23 Ensure 'ASR: Block rebooting machine in Safe Mode' is set to 'Block' (Automated)	91

2.24 Ensure 'ASR: Block untrusted and unsigned processes that run from USB' is set to 'Block' (Automated)	94
2.25 Ensure 'ASR: Block Win32 API calls from Office macros' is set to 'Block' (Automated) ..	97
2.26 Ensure 'ASR: Use advanced protection against ransomware' is set to 'Audit' or higher (Automated)	100
2.27 Ensure 'Check For Signatures Before Running Scan' is set to 'Enabled' (Automated) ..	103
2.28 Ensure 'Cloud Block Level' is set to Enabled: High blocking level' or higher (Automated)	106
2.29 Ensure 'Cloud Extended Timeout' is set to '1 or higher, but not 0' (Automated)	109
2.30 Ensure 'Days Until Aggressive Catchup Quick Scan' is set to '7' days (Automated)	112
2.31 Ensure 'Enable Convert Warn To Block' is set to 'Warn verdicts are converted to block' (Automated)	114
2.32 Ensure 'Enable Dynamic Signature Dropped Event Reporting' is set to 'Dynamic Security intelligence update events will be reported.' (Automated)	116
2.33 Ensure 'Enable File Hash Computation' is set to 'Enable' (Automated)	118
2.34 Ensure 'Enable Network Protection' is set to 'Enabled (block mode)' (Automated)	120
2.35 Ensure 'Hide Exclusions From Local Users' is set to 'Enabled' (Automated)	122
2.36 Ensure 'Oobe Enable Rtp And Sig Update' is set to 'Enabled' (Automated)	124
2.37 Ensure 'PUA Protection' is set to 'PUA Protection on' (Automated)	126
2.38 Ensure 'Quick Scan Include Exclusions' is set to '1' (Automated)	129
2.39 Ensure 'Real Time Scan Direction' is set to 'Monitor all files bi-directional' (Automated)	131
2.40 Ensure 'Remote Encryption Protection Aggressiveness' is set to 'Medium' or higher (Automated)	133
2.41 Ensure 'Remote Encryption Protection Configured State' is set to 'Audit: Generate EDR detections without blocking' or higher (Automated)	135
2.42 Ensure 'Scan Parameter' is set to 'Quick Scan' or higher (Automated)	137
2.43 Ensure 'Schedule Scan Day' is set to 'Enabled: 0' or higher, but not '8' (Automated) ...	143
2.44 Ensure 'Schedule Scan Time' is set to '1' or higher (Automated)	139
2.45 Ensure 'Schedule Quick Scan Time' is set to '1' or higher (Automated)	143
2.46 Ensure 'Submit Samples Consent' is set to 'Enabled: Send safe samples automatically' or higher (Automated)	146
2.47 Ensure 'Signature Update Interval' is set to '4' or fewer, but not '0' (Automated)	146
2.48 Ensure 'Remediation action for Moderate severity threats' is set to 'Quarantine or Remove' (Automated)	151
2.49 Ensure 'Remediation action for High severity threats' is set to 'Quarantine or Remove' (Automated)	153
2.50 Ensure 'Remediation action for Severe threats' is set to 'Quarantine or Remove' (Automated)	155

Appendix: Summary Table 157

Appendix: Change History 162

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the [CIS Website](#). They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- [CIS Configuration Assessment Tool \(CIS-CAT® Pro Assessor\)](#)
- [CIS Benchmarks™ Certified 3rd Party Tooling](#)

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that **ALL** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.
- **Use the most recent version of a Benchmark:** This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed [Build Kits](#) for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
 - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
 - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
 - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
 - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
 - When the initial deployment above is completed successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the [CIS Website](#). All other formats of the CIS Benchmarks™ (MS Word, Excel, and [Build Kits](#)) are available for CIS [SecureSuite®](#) members.

CIS-CAT® Pro is also available to CIS [SecureSuite®](#) members.

Target Technology Details

This document provides prescriptive guidance for establishing a secure configuration posture for **Microsoft Defender Antivirus**.

This secure configuration guide is based on **Microsoft Defender Antivirus** and is intended for all releases of the Microsoft Windows Operating Systems. This secure configuration guide was tested against **Microsoft Windows 11 version 25H2 Enterprise** edition.

Ensure that the latest version of this benchmark is downloaded, as it contains new and updated policies that are released by Microsoft. This benchmark follows the CIS on-prem Windows OS Benchmarks as closely as possible. Microsoft is continually updating Intune to support settings that are backed by Group Policy. Note that this benchmark is based off settings that were available and apply without known issues to MDM systems via **Intune configuration profiles** and the **Endpoint Security Blade** at the **time of publication**.

To obtain the latest version of this secure configuration guide, please visit the [CIS Website](#) or visit the [CIS WorkBench Community](#). If you have questions, comments, or have identified ways to improve this guide, please write to us at benchmarkinfo@cisecurity.org.

Intended Audience

The Microsoft Intune Windows Benchmarks are written for **MDM-joined** systems using Microsoft Intune device configuration profiles only. This benchmark is **not** intended for use on standalone or workgroup systems, systems joined to and receive policies from Active Directory, or systems created, maintained, or used in other Cloud offerings. This benchmark covers supported endpoint states for **Entra Hybrid Joined** and **Entra Joined** systems that receive policies from **Microsoft Intune** using **Configuration Profiles** and the **Endpoint Security Blade** only.

The Microsoft Defender Antivirus Benchmark includes settings available across the following Microsoft Defender Antivirus plans. If a recommendation falls outside the **Microsoft Defender Antivirus (Built-in, baseline protection)** plan, this will be noted within the recommendation, and an exception to the recommendation will be needed.

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Business, (SMB-focused EDR, simplified)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
<code>Monospace font</code>	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
<code><Monospace font in brackets></code>	Text set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like Notes , Warnings , or Cautions (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1 - Workstation**

This profile is for Corporate/Enterprise Environments and is considered general use.

Items in this profile intend to:

- be the starting baseline for most organizations;
- be practical and prudent;
- provide a clear security benefit; and
- not inhibit the utility of the technology beyond acceptable means.

- **Level 2 - Workstation**

This profile extends the Level 1 (L1) profile and is intended for High Security/Sensitive Data Environment with limited functionality.

Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is more critical than manageability and usability;
- may negatively inhibit the utility or performance of the technology; and
- limit the ability of remote management/access.

Note: Implementation of Level 2 requires that both Level 1 and Level 2 settings are applied.

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

The Center for Internet Security extends special recognition and thanks to the WorkBench Intune Community for their collaboration developing the configuration recommendations contained in this document.

Editor

Caleb Eifert
Jennifer Jarose
Matt Woods

Contributor

Cody White
Daniel Wahlgren
Haemish Edgerton
James Robinson
JJ Milner
Joe Loveless
Jóhannes Kristjánsson
Martin Himken
Phil Chatham
Rex Farabee
Steven Los
William Ferguson

Recommendations

1 Microsoft Defender Antivirus

This section contains recommendations for Microsoft Defender Antivirus.

1.1 Client Interface

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.2 Exclusions

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.3 MAPS

This section contains recommendations for MAPS.

1.3.1 Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures a local override for the configuration to join Microsoft Active Protection Service (MAPS).

The recommended state for this setting is: **Disabled**.

Rationale:

In an enterprise-managed environment, the decision on whether to participate in Microsoft MAPS / Microsoft Defender Antivirus Cloud Protection Service for malicious software reporting should be made centrally to ensure consistent behavior across all systems. Configuring this setting to Disabled ensures that the decision remains under centralized management.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **0**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\Spynet:LocalSettingOverrideSpynetReporting
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Disabled**.

```
Administrative Templates\Windows Components\Microsoft Defender  
Antivirus\MAPS\Configure local setting override for reporting to Microsoft  
MAPS
```

Default Value:

Disabled. (Group Policy will take priority over the local preference setting.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-cloud-protection-microsoft-defender-antivirus?view=o365-worldwide>
2. GRID: MS-00000464
3. Minimum OS CSP: Windows 10, Version 2004 with KB5005101 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.6 <u>Centrally Manage Anti-Malware Software</u> Centrally manage anti-malware software.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

1.3.2 Ensure 'Configure the 'Block at First Sight' feature' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures whether the device checks (in real time) with the Microsoft Active Protection Service (MAPS) before allowing certain content to be run or accessed.

The block at first sight feature works when Microsoft Defender Antivirus encounters a suspicious but undetected file. It then queries the Microsoft cloud protection backend and applies heuristics, machine learning, and automated analysis of the file to determine whether the files are malicious.

The recommended state for this setting is: **Enabled**.

Rationale:

Enabling the Block at First Sight feature enhances threat protection by using next-generation protection to detect new malware and block it within seconds.

Impact:

The block at first sight can block nonportable executable files (such as JS, VBS, or macros) and executable files, running the latest Defender antimalware platform on Windows or Windows Server.

Note: The block at first sight feature requires the following Group Policy settings to be configured to function.

- *Join Microsoft MAPS* must be **enabled**.
- *Send file samples when further analysis is required* should be set to **1 (Send safe samples)** or **3 (Send all samples)**
- *Scan all downloaded files* and attachments must be **enabled**.
- *Turn off real-time protection* must **NOT** be **enabled**.

Warning: This setting requires at least *Microsoft Defender for Endpoint Plan 1 (Foundational enterprise endpoint protection)* to function. If *Plan 1* is not in use, an exception to this recommendation is required.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **0**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\Spynet:DisableBlockAtFirstSeen
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Enabled**:

```
Administrative Templates\Microsoft Defender Antivirus\MAPS\Configure the  
'Block at First Sight' feature
```

Default Value:

Not Configured.

References:

1. <https://learn.microsoft.com/en-us/defender-endpoint/configure-block-at-first-sight-microsoft-defender-antivirus>
2. GRID: MS-00000639

Additional Information:

- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v8	10.7 <u>Use Behavior-Based Anti-Malware Software</u> Use behavior-based anti-malware software.		●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

1.4 Microsoft Defender Exploit Guard

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.5 MpEngine

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.6 Network Inspection System

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.7 Quarantine

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.8 Real-time Protection

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.8.1 Ensure 'Turn on process scanning whenever real-time protection is enabled' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures process scanning when real-time protection is turned on. This helps to catch malware which could start when real-time protection is turned off.

The recommended state for this setting is: **Enabled**.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **0**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time  
Protection:DisableScanOnRealtimeEnable
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Enabled**:

```
Administrative Templates\Microsoft Defender Antivirus\Real-Time  
Protection\Turn on process scanning whenever real-time protection is enabled
```

Default Value:

Enabled.

References:

1. GRID: MS-00000660

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

1.9 Remediation

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.10 Reporting

This section contains recommendations for Reporting.

1.10.1 Ensure 'Configure Watson events' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 - Workstation

Description:

This policy setting determines whether Watson events are sent to Microsoft. Watson events are the reports that get sent to Microsoft when a program or service crashes or fails, including the possibility of automatic submission.

The recommended state for this setting is: **Disabled**.

Rationale:

Crash reports submitted via Watson events may contain information that could expose sensitive data or internal system details to Microsoft. In high-security environments where data residency, confidentiality, or regulatory compliance is a concern, preventing automatic transmission of this telemetry reduces the risk of unintended data disclosure.

Impact:

Microsoft will not receive crash telemetry from the device. This may reduce Microsoft's ability to diagnose product issues affecting the organization and could delay vendor support in crash-related investigations.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\Reporting\DisableGenericRePorts
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Disabled**.

```
Administrative Templates\Windows Components\Microsoft Defender  
Antivirus\Reporting\Configure Watson events
```

Default Value:

Enabled. (Watson events *will* be sent to Microsoft automatically when a program or service crashes or fails.)

References:

1. GRID: MS-00000474
2. Minimum OS CSP: Windows 10, Version 2004 with KB5005101 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			
v7	13.3 <u>Monitor and Block Unauthorized Network Traffic</u> Deploy an automated tool on network perimeters that monitors for unauthorized transfer of sensitive information and blocks such transfers while alerting information security professionals.			●

1.11 Scan

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.12 Security Intelligence Updates

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.13 Threats

This section is intentionally blank and exists to ensure the structure of the Intune benchmarks are consistent.

1.14 Ensure 'Turn off routine remediation' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures whether Microsoft Defender Antivirus automatically takes action on all detected threats. The action to be taken on a particular threat is determined by the combination of the policy-defined action, user-defined action, and the signature-defined action.

The recommended state for this setting is: **Disabled**.

Rationale:

If this setting is enabled, Microsoft Defender prompts the user to take action on detected threats. Allowing users to choose threat remediation actions is not considered a best practice, as it can lead to inconsistent or unsafe responses.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **0**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender:DisableRoutinelyTakingAction
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Disabled**:

```
Administrative Templates\Windows Components\Microsoft Defender Antivirus\Turn  
off routine remediation
```

Default Value:

Disabled. (Microsoft Defender Antivirus automatically takes action on all detected threats after a nonconfigurable delay of approximately five seconds.)

References:

1. <https://learn.microsoft.com/en-us/defender-endpoint/configure-remediation-microsoft-defender-antivirus>
2. GRID: MS-00000670

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2 Defender

This section contains recommendations for Defender.

2.1 Ensure 'Allow Archive Scanning' is set to 'Allowed' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures whether Microsoft Defender Antivirus scans for malicious software and unwanted software in archive files such as **.ZIP** or **.CAB** files.

The recommended state for this setting is: **Allowed. Scans the archive files..**

Rationale:

Archive files such as **.zip**, **.rar**, **.7z**, and **.iso** are a common and effective way threat actors hide malware, bypass basic defenses, and to delay detection.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **0**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Scan:DisableArchiveScanning
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allowed. Scans the archive files.:**

```
Defender\Allow Archive Scanning
```

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow Archive Scanning** to **Allowed**

Default Value:

Enabled.

References:

1. GRID: MS-00000663

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.2 Ensure 'Allow Behavior Monitoring' is set to 'Allowed' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting allows you to configure behavior monitoring for Microsoft Defender Antivirus.

The recommended state for this setting is: **Allowed. Turns on real-time behavior monitoring..**

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:AllowBehaviorMonitoring
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allowed. Turns on real-time behavior monitoring..**

Defender\Allow Behavior Monitoring

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow Behavior Monitoring** to **Allowed. Turns on real-time behavior monitoring.**

Default Value:

Enabled. (Behavior monitoring will be enabled.)

References:

1. <https://learn.microsoft.com/en-us/windows/security/threat-protection/microsoft-defender-antivirus/configure-real-time-protection-microsoft-defender-antivirus>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#allowbehaviormonitoring>
3. Minimum OS CSP: Windows 10, Version 1607 and later
4. GRID: MS-00000472

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.7 <u>Use Behavior-Based Anti-Malware Software</u> Use behavior-based anti-malware software.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.3 Ensure 'Allow Cloud Protection' is set to 'Allowed' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures Microsoft Active Protection Service (MAPS). Microsoft MAPS is designed to help Microsoft continually update and improve definitions of malware, spyware and other potentially unwanted software and to help Microsoft improve Windows Defender and related technologies.

The recommended state for this setting is: **Allowed. Turns on Cloud Protection..**

Rationale:

Cloud protection works with Microsoft Defender Antivirus to provide intelligent, real-time threat detection. Microsoft strongly recommends enabling cloud protection, as several advanced security features in Microsoft Defender for Endpoint rely on it to function properly. To fully take advantage of these protections, including several ASR rules, this setting must be enabled to allow for MAPS reporting.

Impact:

MAPS will send detailed information about malware and potentially unwanted software, including the full path to the software, and detailed information about how the software has affected the device.

Warning: Changes to this setting aren't applied when tamper protection is enabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is in effect when the following registry value **does not exist**, or when it exists with a value of **2**:

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Spynet:SpynetReporting
--

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allowed. Turns on Cloud Protection..**

Defender\Allow Cloud Protection

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow Cloud Protection** to **Allowed. Turns on Cloud Protection.**

Default Value:

Disabled. (Microsoft MAPS / Microsoft Defender Antivirus Cloud Protection Service will not be joined.)

References:

1. GRID: MS-00000465
2. Minimum OS CSP: Windows 10, Version 2004 with KB5005101 and later
3. <https://learn.microsoft.com/en-us/defender-endpoint/enable-cloud-protection-microsoft-defender-antivirus#use-group-policy-to-turn-on-cloud-protection>
4. <https://learn.microsoft.com/en-us/defender-endpoint/enable-cloud-protection-microsoft-defender-antivirus>
5. https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender?WT.mc_id=Portal-fx#allowcloudprotection

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.7 <u>Use Behavior-Based Anti-Malware Software</u> Use behavior-based anti-malware software.			

2.4 Ensure 'Allow Email Scanning' is set to 'Allowed' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures e-mail scanning. When e-mail scanning is enabled, the engine will parse the mailbox and mail files, according to their specific format, to analyze the mail bodies and attachments. Several e-mail formats are currently supported, for example: pst (Outlook), dbx, mbx, mime (Outlook Express), binhex (Mac).

The recommended state for this setting is: **Allowed. Turns on email scanning..**

Rationale:

All email content should be scanned using an antivirus solution such as Microsoft Defender Antivirus, since email attachments are a frequently used method for introducing malicious software into systems.

Impact:

Enabling email scanning may add minor latency when opening or processing mail files.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:AllowEmailScanning
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allowed. Turns on email scanning..**

```
Defender\Allow Email Scanning
```

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow Email Scanning** to **Allowed. Turns on email scanning.**

Default Value:

Disabled. (E-mail scanning by Microsoft Defender Antivirus will be disabled.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/configure-advanced-scan-types-microsoft-defender-antivirus?view=o365-worldwide#settings-and-locations>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#allowemailscanning>
3. Minimum OS CSP: Windows 10, Version 1607 and later
4. GRID: MS-00000477

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.5 Ensure 'Allow Full Scan Removable Drive Scanning' is set to 'Allowed' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting manages whether to scan for malicious and unwanted software in the contents of removable drives, such as USB flash drives, when running a full scan.

The recommended state for this setting is: **Allowed. Scans removable drives..**

Rationale:

All drives, including any connected removable drives, should be scanned as these devices present a higher risk of introducing malicious software from external, unmanaged systems into the enterprise environment.

Impact:

Removable drives will be scanned during any type of scan by Microsoft Defender Antivirus.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:AllowFullScanRemovableDriveScanning
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allowed. Scans removable drives..**

Defender Antivirus\Allow Full Scan Removable Drive Scanning

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow Full Scan Removable Drive Scanning** to **Allowed. Scans removable drives.**

Default Value:

Disabled. (Removable drives will not be scanned during a full scan. Removable drives may still be scanned during quick scan and custom scan.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/configure-advanced-scan-types-microsoft-defender-antivirus?view=o365-worldwide#settings-and-locations>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#allowfullscanremovabledrivescanning>
3. Minimum OS CSP: Windows 10, Version 1607 and later
4. GRID: MS-00000476

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.4 <u>Configure Automatic Anti-Malware Scanning of Removable Media</u>			

Controls Version	Control	IG 1	IG 2	IG 3
	Configure anti-malware software to automatically scan removable media.			
v7	8.4 <u>Configure Anti-Malware Scanning of Removable Devices</u> Configure devices so that they automatically conduct an anti-malware scan of removable media when inserted or connected.	●	●	●

2.6 Ensure 'Allow On Access Protection' is set to 'Allow' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures monitoring for file and program activity.

The recommended state for this setting is: **Allow**.

Rationale:

Attackers routinely deploy new malware variants that can change faster than signature updates. Enabling this setting ensures that file and program activity are continually monitored.

Impact:

None - this is the default behavior.

Warning: Changes to this setting aren't applied when tamper protection is enabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time  
Protection:DisableOnAccessProtection
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allow**:

```
Defender\Allow On Access Protection
```

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow On Access Protection** to **Allow**

Default Value:

Enabled.

References:

1. GRID: MS-00000659

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.7 Ensure 'Allow Realtime Monitoring' is set to 'Allowed' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures real-time protection prompts for known malware detection.

Microsoft Defender Antivirus generates alerts when malware or potentially unwanted software attempts to install or execute on a system.

The recommended state for this setting is: **Allowed. Turns on and runs the real-time monitoring service..**

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

Impact:

None - this is the default behavior.

Warning: Changes to this setting aren't applied when tamper protection is enabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:AllowRealtimeMonitoring
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allowed. Turns on and runs the real-time monitoring service..**

Defender\Allow Realtime Monitoring

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow Realtime Monitoring** to **Allowed. Turns on and runs the real-time monitoring service.**

Default Value:

Allowed. (Real-time protection is turned on.)

References:

1. <https://learn.microsoft.com/en-us/windows/security/threat-protection/microsoft-defender-antivirus/configure-real-time-protection-microsoft-defender-antivirus>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/configure-protection-features-microsoft-defender-antivirus?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#allowrealtimemonitoring>
4. Minimum OS CSP: Windows 10, Version 1607 and later
5. GRID: MS-00000471

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.8 Ensure 'Allow scanning of all downloaded files and attachments' is set to 'Allowed' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures scanning for all downloaded files and attachments.

The recommended state for this setting is: **Allowed**.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:AllowIOAVProtection
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allowed**.

```
Defender\Allow scanning of all downloaded files and attachments
```

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow scanning of all downloaded files and attachments** to **Allowed**

Default Value:

Enabled. (All downloaded files and attachments will be scanned.)

References:

1. <https://learn.microsoft.com/en-us/windows/security/threat-protection/microsoft-defender-antivirus/configure-real-time-protection-microsoft-defender-antivirus>
2. Minimum OS CSP: Windows 10, Version 1607 and later
3. GRID: MS-00000470

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.9 Ensure 'Allow Script Scanning' is set to 'Allowed' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting allows script scanning to be turned on/off. Script scanning intercepts scripts then scans them before they are executed on the system.

The recommended state for this setting is: **Allowed**.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:AllowScriptScanning
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Allowed**.

```
Defender\Allow Script Scanning
```

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Allow Script Scanning** to **Allowed**

Default Value:

Enabled. (Script scanning will be enabled.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/configure-advanced-scan-types-microsoft-defender-antivirus?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#allowscriptscanning>
3. Minimum OS CSP: Windows 10, Version 1607 and later
4. GRID: MS-00000473

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.7 <u>Use Behavior-Based Anti-Malware Software</u> Use behavior-based anti-malware software.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.10 Ensure 'ASR: Block abuse of exploited vulnerable signed drivers' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule prevents an application from writing a vulnerable signed driver to disk.

The recommended state for this setting is: **Block**.

Note: The *Block abuse of exploited vulnerable signed drivers* setting does not block a driver that already exists on the system from being loaded.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect systems.

Vulnerable signed drivers can be exploited by local applications that have sufficient privileges to gain access to the kernel. This enables attackers to disable or circumvent security solutions, eventually leading to system compromise.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **56a863a9-875e-4185-98a7-b882c64b5ce5=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block abuse of exploited vulnerable signed drivers (Device)
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000641
6. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
7. Minimum OS CSP: Windows 10, version 1709 and later
8. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference#block-abuse-of-exploited-vulnerable-signed-drivers>

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.		●	●
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.		●	●

2.11 Ensure 'ASR: Block Adobe Reader from creating child processes' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule blocks Adobe Reader from creating processes.

The recommended state for this setting is: **Block**.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Malware can download and launch payloads and break out of Adobe Reader through social engineering or exploits. By blocking child processes from being generated by Adobe Reader, malware attempting to use Adobe Reader as an attack vector are prevented from spreading.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block Adobe Reader from creating child processes
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000642
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.12 Ensure 'ASR: Block all Office applications from creating child processes' is set to 'Audit' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule blocks Office apps from creating child processes. Office apps include Word, Excel, PowerPoint, OneNote, and Access.

The recommended state for this setting is: **Audit**. Configuring this setting to **Block** also conforms to the benchmark.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Creating malicious child processes is a common malware strategy. Malware that abuses Office as a vector often runs VBA macros and exploit code to download and attempt to run more payloads. However, some legitimate line-of-business applications might also generate child processes for benign purposes, such as spawning a command prompt or using PowerShell to configure registry settings.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Warning: Prior to configuring this rule in **Block** mode, it should be enabled in **Audit** mode to verify that it does not introduce issues, especially for Microsoft Outlook.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **d4f940ab-401b-4efc-aadc-ad5f3c50688a=1** (Block) or **d4f940ab-401b-4efc-aadc-ad5f3c50688a=2** (Audit).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Audit** or **Block**.

```
Defender\Block all Office applications from creating child processes
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000643
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.13 Ensure 'ASR: Block credential stealing from the Windows local security authority subsystem' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule helps prevent credential stealing by locking down Local Security Authority Subsystem Service (LSASS).

The recommended state for this setting is: **Block**.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

LSASS authenticates users who sign in on a Windows computer. Microsoft Defender Credential Guard in Windows normally prevents attempts to extract credentials from LSASS. Some organizations can't enable Credential Guard on all of their computers because of compatibility issues with custom smartcard drivers or other programs that load into the Local Security Authority (LSA). In these cases, attackers can use tools like Mimikatz to scrape cleartext passwords and NTLM hashes from LSASS.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Note: Enabling this rule doesn't provide additional protection if LSA protection is enabled since the ASR rule and LSA protection work similarly. However, when LSA protection cannot be enabled, this rule can be configured to provide equivalent protection against malware that target **lsass.exe**.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block credential stealing from the Windows local security authority subsystem
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000644
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.14 Ensure 'ASR: Block executable content from email client and webmail' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule blocks email opened within the Microsoft Outlook application, or Outlook.com and other popular webmail providers from propagating the following file types:

- Executable files (such as .exe, .dll, or .scr)
- Script files (such as a PowerShell .ps1, Visual Basic .vbs, or JavaScript .js file)

The recommended state for this setting is: **Block**.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **be9ba2d9-53ea-4cdc-84e5-9b1eeee46550=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block executable content from email client and webmail
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000645
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.15 Ensure 'ASR: Block executable files from running unless they meet a prevalence, age, or trusted list criterion' is set to 'Audit' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule blocks executable files, such as .exe, .dll, or .scr, from launching.

The recommended state for this setting is: **Audit** or higher. Configuring this setting to **Block** also conforms to the benchmark.

Note: Cloud-delivered protection must be enabled to use this rule.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Launching untrusted or unknown executable files can be risky, as it might not be initially clear if the files are malicious.

Organizations may find implementing **Block** to be too strict, however in **Audit** mode there is still valuable information that can be logged for threat hunters to sift through and analyze.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center. To parse audit logs effectively an organization may need to implement a SIEM solution.

Warning: Prior to configuring this rule in **Block** mode, it should be enabled in **Audit** mode to verify that it does not introduce issues, especially for Microsoft Outlook. This rule **will** block legitimate programs.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **01443614-cd74-433a-b99e-2ecdc07bfc25=1** (Block) or **01443614-cd74-433a-b99e-2ecdc07bfc25=2** (Audit).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Audit** or **Block**.

```
Defender\Block executable files from running unless they meet a prevalence, age, or trusted list criterion
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. <https://learn.microsoft.com/en-us/defender-endpoint/enable-cloud-protection-microsoft-defender-antivirus>
6. GRID: MS-00000646
7. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.16 Ensure 'ASR: Block execution of potentially obfuscated scripts' is set to 'Audit' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule detects suspicious properties within an obfuscated script.

The recommended state for this setting is: **Audit**. Configuring this setting to **Block** also conforms to the benchmark.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Script obfuscation is a common technique that both malware authors and legitimate applications use to hide intellectual property or decrease script loading times. Malware authors also use obfuscation to make malicious code harder to read, which hampers close scrutiny by humans and security software.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Note: Cloud-delivered protection must be enabled to use this rule.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **5beb7efe-fd9a-4556-801d-275e5ffc04cc=1** (Block) or **5beb7efe-fd9a-4556-801d-275e5ffc04cc=2** (Audit).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Audit** or **Block**.

```
Defender\Block execution of potentially obfuscated scripts
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000647
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.17 Ensure 'ASR: Block JavaScript or VBScript from launching downloaded executable content' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule prevents scripts from launching potentially malicious downloaded content.

The recommended state for this setting is: **Block**.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Malware written in JavaScript or VBScript often acts as a downloader to fetch and launch other malware from the Internet. Although not common, line-of-business applications sometimes use scripts to download and launch installers.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **d3e037e1-3eb8-44c8-a917-57927947596d=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block JavaScript or VBScript from launching downloaded executable content
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000648
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.18 Ensure 'ASR: Block Office applications from creating executable content' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule prevents Office apps, including Word, Excel, and PowerPoint, from being used as a vector to persist malicious code on disk.

The recommended state for this setting is: **Block**.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Malware that abuses Office as a vector might attempt to save malicious components to disk that would survive a computer reboot and persist on the system. This rule defends against this persistence technique by blocking access (open/execute) to the code written to disk. This rule also blocks execution of untrusted files that might have been saved by Office macros that are allowed to run in Office files.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **3b576869-a4ec-4529-8536-b80a7769e899=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block Office applications from creating executable content
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000649
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.19 Ensure 'ASR: Block Office applications from injecting code into other processes' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule blocks Office apps from injecting code into other processes. Office apps included in this setting are Word, Excel, PowerPoint, and OneNote.

The recommended state for this setting is: **Block**.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Attackers might attempt to use Office apps to migrate malicious code into other processes through code injection, so the code can masquerade as a clean process. There are no known legitimate business purposes for using code injection.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Note: While Microsoft states that "there are no known legitimate business purposes for using code injection", this ASR will trigger on legitimate processes so it is recommended to start in **Audit** mode before creating a list of exceptions and moving finally to **Block**.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **75668c1f-73b5-4cf0-bb93-3ecf5cb7cc84=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block Office applications from injecting code into other processes
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000650
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.20 Ensure 'ASR: Block Office communication application from creating child processes' is set to 'Audit' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule prevents Outlook from creating child processes, while still allowing legitimate Outlook functions.

The recommended state for this setting is: **Audit**. Configuring this setting to **Block** also conforms to the benchmark.

Rationale:

This ASR rule protects against social engineering attacks and prevents exploiting code from abusing vulnerabilities in Outlook. It also protects against Outlook rules and forms exploits that attackers can use when a user's credentials are compromised.

Impact:

This rule will block DLP policy tips and ToolTips in Outlook, and applies to Outlook and Outlook.com only.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **26190899-1602-49e8-8b27-eb1d0a1ce869=1** (Block) or **26190899-1602-49e8-8b27-eb1d0a1ce869=2** (Audit).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Audit** or **Block**.

```
Defender\Block Office communication application from creating child processes
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000651
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.21 Ensure 'ASR: Block persistence through WMI event subscription' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule prevents malware from abusing WMI to attain persistence on a device.

Note: If CcmExec.exe (SCCM Agent) is detected on the device, the ASR rule is classified as "not applicable" in Defender for Endpoint settings in the Microsoft Defender portal.

The recommended state for this setting is: **Block**.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Fileless threats employ various tactics to stay hidden, to avoid being seen in the file system, and to gain periodic execution control. Some threats can abuse the WMI repository and event model to stay hidden.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **e6db77e5-3df2-4cf1-b95a-636979351e5b=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block persistence through WMI event subscription
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000652
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.22 Ensure 'ASR: Block process creations originating from PSExec and WMI commands' is set to 'Audit' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule blocks processes created through PsExec and WMI from running.

The recommended state for this setting is: **Audit**. Configuring this setting to **Block** also conforms to the benchmark.

Rationale:

There's a risk of malware abusing functionality of PsExec and WMI for command and control purposes, or to spread an infection throughout an organization's network.

Impact:

Warning: Only use this rule if you're managing your devices with Intune or another MDM solution. This rule is incompatible with management through Microsoft Endpoint Configuration Manager because this rule blocks WMI commands the Configuration Manager client uses to function correctly.

It is recommended to start with Audit mode and move to Block.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **d1e49aac-8f56-4280-b9ba-993a6d77406c=1** (Block) or **d1e49aac-8f56-4280-b9ba-993a6d77406c=2** (Audit).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Audit** or **Block**.

```
Defender\Block process creations originating from PSEXEC and WMI commands
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. <https://learn.microsoft.com/en-us/defender-endpoint/enable-cloud-protection-microsoft-defender-antivirus>
6. GRID: MS-00000467
7. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.23 Ensure 'ASR: Block rebooting machine in Safe Mode' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule prevents the execution of certain commands to restart the system in Safe Mode.

The recommended state for this setting is: **Block**.

Note: Safe Mode is still accessible manually from the Windows Recovery Environment.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

When a system is in Safe Mode, many security controls are disabled or operate with reduced functionality, which can allow attackers to execute tampering commands or encrypt files. This rule mitigates that risk by blocking commonly abused commands, such as 'bcdedit' and 'bootcfg', that are used to restart systems into Safe Mode.

Impact:

The system will not start in Safe Mode when using commands such as 'bcdedit' and 'bootcfg'.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **33ddedf1-c6e0-47cb-833e-de6133960387=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1|33ddedf1-c6e0-47cb-833e-de6133960387=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block rebooting machine in Safe Mode
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. GRID: MS-00000653

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.24 Ensure 'ASR: Block untrusted and unsigned processes that run from USB' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

With this rule, admins can prevent unsigned or untrusted executable files from running from USB removable drives, including SD cards. Blocked file types include executable files (such as .exe, .dll, or .scr).

The recommended state for this setting is: **Block**.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Impact:

Files copied from the USB to the disk drive will be blocked by this rule if and when it's about to be executed on the disk drive.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block untrusted and unsigned processes that run from USB
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000654
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.25 Ensure 'ASR: Block Win32 API calls from Office macros' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule prevents VBA macros from calling Win32 APIs. Office VBA enables Win32 API calls.

The recommended state for this setting is: **Block**.

Rationale:

Malware can abuse VBA macro calls with various methods, such as calling Win32 APIs to launch malicious shellcode without writing anything directly to disk. Most organizations don't rely on the ability to call Win32 APIs in their day-to-day functioning, even if they use macros in other ways.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center. Legitimate applications that use Office VBA macros to call Win32 APIs (e.g., for automation or system integration) will be blocked and must be added to the exclusion list.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **92e97fa1-2edf-4476-bdd6-9dd0b4dddc7b=1** (Block).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Block**.

```
Defender\Block Win32 API calls from Office macros
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. GRID: MS-00000655
6. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.26 Ensure 'ASR: Use advanced protection against ransomware' is set to 'Audit' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This rule provides an extra layer of protection against ransomware. It uses both client and cloud heuristics to determine whether a file resembles ransomware. This rule doesn't block files that have one or more of the following characteristics:

- The file has already been found to be unarmful in the Microsoft cloud.
- The file is a valid signed file.
- The file is prevalent enough to not be considered as ransomware.
- The rule tends to err on the side of caution to prevent ransomware.

The recommended state for this setting is: **Audit**. Configuring this setting to **Block** also conforms to the benchmark.

Rationale:

This ASR rule can help an organization enhance its protection against ransomware by using both cloud and local heuristics.

Note: Cloud-delivered protection must be enabled to use this rule.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center. In order to parse audit logs effectively an organization may need to implement a SIEM solution.

Implementing this recommendation could impact certain workflows, making it unsuitable for universal enforcement across the organization without first adding exceptions.

Warning: Prior to configuring this rule in **Block** mode, it should be enabled in **Audit** mode to verify that it does not introduce issues, especially for Microsoft Outlook. This rule **will** block legitimate programs.

Audit:

1. Navigate to the following registry location and note the *WinningProvider* GUID. This value confirms under which User GUID the policy is set.

```
HKLM\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:AttackSurfaceReductionRules_WinningProvider
```

2. Navigate to the following registry location and confirm the value contains **c1db55ab-c21a-4637-bb3f-a12568109d35=1** (Block) or **c1db55ab-c21a-4637-bb3f-a12568109d35=2** (Audit).

```
HKLM\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Defender:AttackSurfaceReductionRules
```

Note: The following key can also be queried for the requisite value, however if **Tamper Protection** is enabled it will only be readable by SYSTEM

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:ASRRules

Note #2: The contents of **ASRRules** is a single large string containing the GUID of each ASR rule separated with a pipe delimiter. Below is an example of what the Registry would display if all recommendations that allow **Audit** or **Block** are set to **Block**.

```
56a863a9-875e-4185-98a7-b882c64b5ce5=1|7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c=1|D4F940AB-401B-4EFC-AADC-AD5F3C50688A=1|9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2=1|BE9BA2D9-53EA-4CDC-84E5-9B1EEEE46550=1|5BEB7EFE-FD9A-4556-801D-275E5FFC04CC=1|D3E037E1-3EB8-44C8-A917-57927947596D=1|3B576869-A4EC-4529-8536-B80A7769E899=1|75668C1F-73B5-4CF0-BB93-3ECF5CB7CC84=1|26190899-1602-49e8-8b27-eb1d0a1ce869=1|e6db77e5-3df2-4cf1-b95a-636979351e5b=1|b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4=1|92E97FA1-2EDF-4476-BDD6-9DD0B4DDDC7B=1
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Audit** or **Block**.

```
Defender\Use advanced protection against ransomware
```

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>
3. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#attacksurfacereductionrules>
4. <https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction-rules-reference>
5. <https://learn.microsoft.com/en-us/defender-endpoint/enable-cloud-protection-microsoft-defender-antivirus>
6. GRID: MS-00000656
7. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.27 Ensure 'Check For Signatures Before Running Scan' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting controls whether to check for new virus and spyware security intelligence before running a scan.

The recommended state for this setting is: **Enabled**.

Note: This setting applies to scheduled scans and has no effect on scans that are initiated manually from the user interface or to the ones that have been started from the command line using **mpcmdrun -Scan**.

Rationale:

A malware scan is only as effective as the threat definitions it uses. Running a scan with outdated intelligence significantly reduces detection accuracy and can create a false sense of security.

Impact:

Checking for updated security intelligence can add a small amount of overhead before a scan begins.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\Scan:CheckForSignaturesBeforeRunningScan
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Enabled**:

Defender\Check For Signatures Before Running Scan

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Check For Signatures Before Running Scan** to **Enabled**

Default Value:

Disabled. (The scan will start using the existing security intelligence.)

References:

1. GRID: MS-00000662

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v8	10.2 Configure Automatic Anti-Malware Signature Updates Configure automatic updates for anti-malware signature files on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.28 Ensure 'Cloud Block Level' is set to Enabled: High blocking level' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting determines how aggressive Microsoft Defender Antivirus will be in blocking and scanning suspicious files. Threat data from this feature is analyzed in real time using, machine learning models, and behavioral analysis.

Options for blocking levels are:

- **Default blocking level** provides strong detection without increasing the risk of detecting legitimate files.
- **High blocking level** applies a strong level of detection while optimizing client performance (but can also give a greater chance of false positives).
- **High + blocking level** applies extra protection measures (might affect client performance and increase the chance of false positives).
- **Zero tolerance blocking level** blocks all unknown executables.

The recommended state for this setting is: **Enabled: High blocking level**. Configuring this setting to **High+ blocking level**, or **Zero tolerance blocking level** also conforms to the benchmark.

Rationale:

Attackers routinely deploy new malware variants that can change faster than signature updates. Enabling cloud protection can close this gap with its ability to detect and block new, unknown, and fast-moving threats.

Impact:

Although higher protection levels can increase detection of new threats, it can also raise the potential for false positives.

Note: The select cloud protection level feature requires the following Group Policy setting to be configured to function.

- *Join Microsoft MAPS* must be **enabled**.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This group policy setting is backed by the following registry location with a **REG_DWORD** value of **2**, **4**, or **6**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\MpEngine:MpCloudBlockLevel
```

Note: If a Resultant Set of Policy with Group Policy (RSOP) is run on the system, and **Default blocking level** is selected, it can produce misleading results. A setting with a **0** value is read as disabled by RSOP.

Remediation:

To establish the recommended configuration via GP, set the following UI path to **Enabled: High blocking level**, **High+ blocking level**, or **Zero tolerance blocking level**:

```
Computer Configuration\Policies\Administrative Templates\Windows  
Components\Microsoft Defender Antivirus\MpEngine\Select cloud protection  
level
```

Note: This Group Policy path is provided by the Group Policy template **WindowsDefender.admx/adml** that is included with the Microsoft Windows 11 version 24H2 Administrative Templates (or newer).

Default Value:

Enabled: Default blocking level. (Provides strong detection without increasing the risk of detecting legitimate files.)

References:

1. GRID: MS-00000657

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v8	10.7 <u>Use Behavior-Based Anti-Malware Software</u> Use behavior-based anti-malware software.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.29 Ensure 'Cloud Extended Timeout' is set to '1 or higher, but not 0' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures the Cloud Extended Timeout value for Microsoft Defender Antivirus cloud-delivered protection. The extended timeout determines how long Microsoft Defender waits for a response from the cloud-based protection service before allowing or blocking suspicious content.

The recommended state for this setting is: **1** or higher, but not **0**.

Note: The default cloud check timeout is 10 seconds. The extended cloud check feature extends the time in seconds, up to an additional 50 seconds. For example, if the desired timeout is 60 seconds, specify 50 seconds in this setting, which will enable the extended cloud check feature, and will raise the total time to 60 seconds.

Note #2: The highest value for this setting is **50** seconds.

Rationale:

Microsoft Defender's cloud-delivered protection provides rapid access to the latest threat intelligence and advanced detection capabilities. If the extended timeout is not configured or is set too low, endpoints may allow potentially malicious files when cloud verdicts are delayed due to network latency or service load.

Impact:

A slight delay may occur when scanning files that require extended cloud analysis, particularly in environments with limited or high-latency internet connectivity.

Note: The Cloud Extended Timeout feature requires the following Group Policy settings to be configured to function.

- *Join Microsoft MAPS* must be **enabled**.
- *Send file samples when further analysis is required* should be set to **1 (Send safe samples)** or **3 (Send all samples)**
- *Block at First Sight* feature must be **enabled**.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1** or higher, but not **0**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\MpEngine:CloudExtendedTimeout
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **1** or higher, but not **0**:

```
Defender\Cloud Extended Timeout
```

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Cloud Extended Timeout** to **1** or higher, but not **0**

Default Value:

10 Seconds.

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#cloudextendedtimeout>
2. <https://learn.microsoft.com/en-us/defender-endpoint/configure-block-at-first-sight-microsoft-defender-antivirus>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v8	10.7 <u>Use Behavior-Based Anti-Malware Software</u> Use behavior-based anti-malware software.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.30 Ensure 'Days Until Aggressive Catchup Quick Scan' is set to '7' days (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures the number of days after the last scan (of any type) before an aggressive Quick Scan is automatically triggered.

The recommended state for this setting is: 7 days.

Rationale:

Antivirus scans should be performed on a regular basis so that malicious software can be detected and remediated before malicious activity occurs.

Impact:

This setting should have no adverse effect on the system.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a REG_DWORD value of 7.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:DaysUntilAggressiveCatchupQuickScan
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to 7 days.

```
Defender\Days Until Aggressive Catchup Quick Scan
```

Default Value:

Disabled. (Aggressive Quick Scans are disabled.)

References:

1. GRID: MS-00000605
2. https://learn.microsoft.com/en-us/windows/client-management/mdm/defender-csp?WT.mc_id=Portal-fx#configurationdaysuntilaggressivecatchupquickscan
3. Minimum OS CSP: Windows 10, version 1607 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.31 Ensure 'Enable Convert Warn To Block' is set to 'Warn verdicts are converted to block' (Automated)

Profile Applicability:

- Level 2 - Workstation

Description:

This policy setting controls whether Microsoft Defender Antivirus network protection will display a warning, or block network traffic.

The recommended state for this setting is: **Warn verdicts are converted to block**.

Rationale:

Potentially suspicious network traffic should be blocked until it has been reviewed, and an exception has been granted.

Impact:

Legitimate network traffic could be blocked by Microsoft Defender Antivirus network protection.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:EnableConvertWarnToBlock
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Warn verdicts are converted to block**.

```
Defender\Enable Convert Warn To Block
```

Default Value:

Disabled. (Network protection will display a warning for warn verdicts.)

References:

1. GRID: MS-00000599
2. https://learn.microsoft.com/en-us/windows/client-management/mdm/defender-csp?WT.mc_id=Portal-fx#configurationenableconvertwarntoblock
3. Minimum OS CSP: Windows 10, version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.32 Ensure 'Enable Dynamic Signature Dropped Event Reporting' is set to 'Dynamic Security intelligence update events will be reported.' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures whether to report Dynamic Signature dropped events. Dynamic Signature events are Microsoft Defender Antivirus log events that relate to cloud-delivered, on-demand threat signatures that Microsoft pushes to endpoints outside of the normal scheduled signature update cycle.

The recommended state for this setting is: **Dynamic Security intelligence update events will be reported..**

Rationale:

Microsoft Defender Antivirus logs Dynamic Signature dropped events when it blocks or removes a file using a dynamically delivered signature, but the signature is not fully processed or applied and is subsequently discarded. This may indicate an issue with signature updates or with the system's ability to properly receive or handle dynamic signatures.

Impact:

Enabling dynamic signature dropped events will generate additional events when this feature is enabled.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\Reporting:EnableDynamicSignatureDroppedEventReporting
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Dynamic Security intelligence update events will be reported.**:

Defender\Enable Dynamic Signature Dropped Event Reporting

Default Value:

Disabled.

References:

1. <https://learn.microsoft.com/en-us/defender-endpoint/configure-notifications-microsoft-defender-antivirus>
2. GRID: MS-00000661

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

2.33 Ensure 'Enable File Hash Computation' is set to 'Enable' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This setting determines whether hash values are computed for files scanned by Microsoft Defender.

The recommended state for this setting is: **Enable**.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to monitor for suspicious and known malicious activity. File hashes are a reliable way of detecting changes to files, and can speed up the scan process by skipping files that have not changed since they were last scanned and determined to be safe. A changed file hash can also be cause for additional scrutiny.

Impact:

This setting could cause performance degradation during initial deployment and for users where new executable content is frequently being created (such as software developers), or where applications are frequently installed or updated.

For more information on this setting, please visit [Security baseline \(FINAL\): Windows 10 and Windows Server, version 2004 - Microsoft Tech Community - 1543631](#).

Note: The impact of this setting should be monitored closely during deployment to ensure user and system performance impact is within acceptable limits.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:EnableFileHashComputation
--

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Enable**.

Defender\Enable File Hash Computation

Default Value:

Disabled. (File hash values are not computed during scans.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/defender-csp#configurationenablefilehashcomputation>
2. GRID: MS-00000469
3. Minimum OS CSP: Windows 10, Version 1903 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)
- Microsoft Defender for Business, (SMB-focused EDR, simplified)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.34 Ensure 'Enable Network Protection' is set to 'Enabled (block mode)' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting controls Microsoft Defender Exploit Guard network protection.

The recommended state for this setting is: **Enabled (block mode)**.

Rationale:

This setting can help prevent employees from using any application to access dangerous domains that may host phishing scams, exploit-hosting sites, and other malicious content on the Internet.

Impact:

Users and applications will not be able to access dangerous domains.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:EnableNetworkProtection
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Enabled (block mode)**:

```
Defender\Enable Network Protection
```

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Enable Network Protection** to **Enabled (block mode)**

Default Value:

Disabled. (Users and applications will not be blocked from connecting to dangerous domains.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/network-protection?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#enablenetworkprotection>
3. GRID: MS-00000468
4. Minimum OS CSP: Windows 10, Version 1709 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.3 <u>Maintain and Enforce Network-Based URL Filters</u> Enforce and update network-based URL filters to limit an enterprise asset from connecting to potentially malicious or unapproved websites. Example implementations include category-based filtering, reputation-based filtering, or through the use of block lists. Enforce filters for all enterprise assets.			
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	7.4 <u>Maintain and Enforce Network-Based URL Filters</u> Enforce network-based URL filters that limit a system's ability to connect to websites not approved by the organization. This filtering shall be enforced for each of the organization's systems, whether they are physically at an organization's facilities or not.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

2.35 Ensure 'Hide Exclusions From Local Users' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting controls whether Microsoft Defender Antivirus exclusions are visible to local users on the system.

The recommended state for this setting is: **If you enable this setting, local users will no longer be able to see the exclusion list in Windows Security App or via PowerShell..**

Note: As of the publication of this Benchmark, the setting configuration state in Intune is the sentence above after *The recommended state for this setting is:* and not *Enabled* as the title states. This was done to keep title length to a minimum.

Rationale:

Only administrators should be able to view and manage Microsoft Defender Antivirus exclusions.

Impact:

Local users will not be able to view Microsoft Defender Antivirus exclusions.

Warning: This setting requires at least *Microsoft Defender for Endpoint Plan 1 (Foundational enterprise endpoint protection)* to function. If *Plan 1* is not in use, an exception to this recommendation is required.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:HideExclusionsFromLocalUsers
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **If you enable this setting, local users will no longer be able to see the exclusion list in Windows Security App or via PowerShell..**

Defender\Hide Exclusions From Local Users

Default Value:

Disabled. (Local users are able to view Microsoft Defender Antivirus exclusions.)

References:

1. GRID: MS-00000597
2. https://learn.microsoft.com/en-us/windows/client-management/mdm/defender-csp?WT.mc_id=Portal-fx#configurationhideexclusionsfromlocalusers
3. Minimum OS CSP: Windows 10, version 1809 and later

Additional Information:

- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v8	10.6 <u>Centrally Manage Anti-Malware Software</u> Centrally manage anti-malware software.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.36 Ensure 'Oobe Enable Rtp And Sig Update' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures whether Real-time Protection and Security Intelligence Updates are enabled during the Out of Box experience (OOBE).

The recommended state for this setting is: **If you enable this setting, real-time protection and Security Intelligence Updates are enabled during OOBE..**

Note: As of the publication of this Benchmark, the setting configuration state in Intune is the sentence above after *The recommended state for this setting is:* and not *Enabled* as the title states. This was done to keep title length to a minimum.

Rationale:

Newly provisioned devices are particularly vulnerable during the Out of Box Experience, as they may not yet have current threat intelligence or active real-time protection. Enabling this setting ensures that Defender's real-time scanning engine and security intelligence are active and up to date before the device is handed to the user, reducing the risk of infection during the provisioning window.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:OobeEnableRtpAndSigUpdate
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **If you enable this setting, real-time protection and Security Intelligence Updates are enabled during OOB**E..

Defender\Oobe Enable Rtp And Sig Update

Default Value:

Enabled. (Real-time Protection and Security Intelligence will be updated during OOB

E.)

References:

1. GRID: MS-00000600
2. <https://learn.microsoft.com/en-us/windows-hardware/customize/desktop/windows-updates-during-oobe-in-windows-11>
3. <https://techcommunity.microsoft.com/blog/microsoft-security-baselines/windows-11-version-24h2-security-baseline/4252801>
4. https://learn.microsoft.com/en-us/windows/client-management/mdm/defender-csp?WT.mc_id=Portal-fx#configurationoobeenabletpandsigupdate
5. Minimum OS CSP: Windows 10, version 1607 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.37 Ensure 'PUA Protection' is set to 'PUA Protection on' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting controls detection and action for Potentially Unwanted Applications (PUA), which are sneaky unwanted application bundlers or their bundled applications, that can deliver adware or malware.

The recommended state for this setting is: **PUA Protection on. Detected items are blocked. They will show in history along with other threats..**

For more information, see this link: [Block potentially unwanted applications with Microsoft Defender Antivirus | Microsoft Docs](#)

Rationale:

Potentially unwanted applications can increase the risk of your network being infected with malware, cause malware infections to be harder to identify, and can waste IT resources in cleaning up the applications. They should be blocked from installation.

Impact:

Applications that are identified by Microsoft as PUA will be blocked at download and install time.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:PUAProtection
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **PUA Protection on. Detected items are blocked. They will show in history along with other threats.**:

Defender\PUA Protection

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **PUA Protection** to **PUA Protection on. Detected items are blocked. They will show in history along with other threats.**

Default Value:

Disabled. (Applications that are identified by Microsoft as PUA will not be blocked.)

References:

1. <https://learn.microsoft.com/en-us/microsoft-365/security/defender-endpoint/detect-block-potentially-unwanted-apps-microsoft-defender-antivirus?view=o365-worldwide>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#puaprotection>
3. Minimum OS CSP: Windows 10, Version 1607 and later
4. GRID: MS-00000462

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)
- Microsoft Defender for Business, (SMB-focused EDR, simplified)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	2.7 <u>Utilize Application Whitelisting</u> Utilize application whitelisting technology on all assets to ensure that only authorized software executes and all unauthorized software is blocked from executing on assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.38 Ensure 'Quick Scan Include Exclusions' is set to '1' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting manages whether or not Microsoft Defender Antivirus scans excluded files and directories when running a Quick Scan.

The recommended state for this setting is: **If you set this setting to 1, all files and directories that are excluded from real-time protection using contextual exclusions are scanned during a quick scan.**

Note: As of the publication of this Benchmark, the setting configuration state in Intune is the sentence above after *The recommended state for this setting is:* and not 1 as the title states. This was done to keep title length to a minimum.

Rationale:

The Real-time Protection feature excludes some files and directories for contextual reasons. This setting ensures that these are scanned during a Quick Scan.

Impact:

A Quick Scan could take longer when including the contextually excluded files and directories.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:QuickScanIncludeExclusions
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **If you set this setting to 1, all files and directories that are excluded from real-time protection using contextual exclusions are scanned during a quick scan.**

```
Defender\Quick Scan Include Exclusions
```

Default Value:

Disabled. (Contextual exclusions are not scanned during Quick Scans.)

References:

1. GRID: MS-00000604
2. <https://learn.microsoft.com/en-us/defender-endpoint/schedule-antivirus-scans>
3. https://learn.microsoft.com/en-us/windows/client-management/mdm/defender-csp?WT.mc_id=Portal-fx#configurationquickscanincludeexclusions
4. Minimum OS CSP: Windows 10, version 1607 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.39 Ensure 'Real Time Scan Direction' is set to 'Monitor all files bi-directional' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures monitoring for incoming and outgoing files, without having to turn off monitoring entirely. This setting only applies to NTFS volumes. For any other file system types, full monitoring of file and program activity will be present on those volumes.

The recommended state for this setting is: **Monitor all files bi-directional**.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to monitor in real-time for suspicious activity.

Impact:

None - this is the default behavior.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **0**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time  
Protection:RealtimeScanDirection
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Monitor all files bi-directional**:

Defender/Real Time Scan Direction

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Real Time Scan Direction** to **Monitor all files bi-directional**

Default Value:

Disabled. (Monitoring for incoming and outgoing files will be enabled.)

References:

1. GRID: MS-00000658

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.40 Ensure 'Remote Encryption Protection Aggressiveness' is set to 'Medium' or higher (Automated)

Profile Applicability:

- Level 2 - Workstation

Description:

This policy setting configures how aggressively Remote Encryption Prevention Protection blocks malicious IP addresses.

The recommended state for this setting is: **Medium: Use cloud aggregation and block when confidence level is above 99%** or higher. Configuring this setting to **High: Use cloud intel and context, and block when confidence level is above 90%** also conforms to the benchmark.

Note: As of the publication of this Benchmark, the setting configuration state in Intune is the sentence above after *The recommended state for this setting is:* and not *Medium* or higher as the title states. This was done to keep title length to a minimum.

Rationale:

This feature can help reduce the likelihood of users visiting malicious websites.

Impact:

Legitimate websites could be detected or blocked by Remote Encryption Prevention Protection depending on the configuration of this feature.

When set to **Medium**, detections or blocks will occur when the confidence level is above 99%.

When set to **High**, detections or blocks will occur when the confidence level is above 90%.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1** or **2**.

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:RemoteEncryptionProtectionAggressiveness

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Medium: Use cloud aggregation and block when confidence level is above 99%** or **High: Use cloud intel and context, and block when confidence level is above 90%**.

Defender\Remote Encryption Protection Aggressiveness
--

Default Value:

Low. (Block only when confidence level is 100%.)

References:

1. GRID: MS-00000603
2. https://learn.microsoft.com/en-us/windows/client-management/mdm/defender-csp?WT.mc_id=Portal-fx#configurationbehavioralnetworkblocksremoteencryptionprotectionremoteencryptionprotectionaggressiveness
3. Minimum OS CSP: Windows 10, version 1607 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.41 Ensure 'Remote Encryption Protection Configured State' is set to 'Audit: Generate EDR detections without blocking' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting sets the mode for Remote Encryption Protection in Microsoft Defender Antivirus, which can detect and block attempts to replace local files with encrypted versions from another device.

The recommended state for this setting is: **Audit: Generate EDR detections without blocking**. Configuring this setting to **Block: Prevent suspicious and malicious behaviors** also conforms to the benchmark.

Note: Configuring the value to either **Default** or **Off** does **not** conform to this benchmark.

Rationale:

This feature assists with detecting and blocks malicious remote encryption behavior, such as when a threat actor attempts to remotely encrypt files on a victim machine using compromised credentials, network channels, or lateral movement techniques.

Impact:

False positives blocking legitimate remote operations could be detected or blocked by this feature.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **2** or **1**.

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:RemoteEncryptionProtectionConfiguredState
--

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Audit: Generate EDR detections without blocking** or **Block: Prevent suspicious and malicious behaviors**.

Defender\Remote Encryption Protection Configured State

Default Value:

Not configured. (Apply defaults, which can vary depending on the antivirus engine version and the platform.)

References:

1. GRID: MS-00000671
2. https://learn.microsoft.com/en-us/windows/client-management/mdm/defender-csp?WT.mc_id=Portal-fx#configurationbehavioralnetworkblocksremoteencryptionprotectionremoteencryptionprotectionconfiguredstate
3. Minimum OS CSP: Windows 10, version 1607 and later

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.42 Ensure 'Scan Parameter' is set to 'Quick Scan' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures the scan type to use during a scheduled scan.

The recommended state for this setting is: **Quick Scan**. Configuring this setting to **Full Scan** also conforms to the benchmark.

Rationale:

Performing antivirus scans helps protect systems, data, and users from a wide range of security threats.

Impact:

If **Quick Scan** is configured, this setting is not expected to negatively impact system performance, as quick scans are designed to be lightweight.

If **Full Scan** is configured, it might negatively impact the system, as a full scan comprehensively scans every file, folder, running process, and system area on the device.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1** or **2**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Scan:ScanParameters
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Quick Scan** or **Full Scan**:

Defender\Scan Parameter

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Scan Parameter** to **Quick Scan** or **Full Scan**

Default Value:

Disabled. (The default scan type will be used.)

References:

1. GRID: MS-00000665

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.43 Ensure 'Schedule Quick Scan Time' is set to '1' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures the time of day at which to perform a daily quick scan.

The recommended state for this setting is: **1** or higher.

Note: The time value is represented as the number of minutes past midnight (00:00). For example, 120 (0x78) is equivalent to 02:00 AM. By default, this setting is set to a time value of 2:00 AM. The schedule is based on local time on the computer where the scan is executing.

Rationale:

Performing a daily quick scan is a consistent, low-impact way to verify that critical parts of the system remain clean.

Impact:

This setting is not expected to negatively impact system performance, as quick scans are designed to be lightweight.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1** or higher.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Scan:ScheduleQuickScanTime
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **1** or higher:

Defender\Schedule Quick Scan Time

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Schedule Quick Scan Time** to **1** or higher

Default Value:

Disabled.

References:

1. GRID: MS-00000666

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.44 Ensure 'Schedule Scan Time' is set to '1' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures the time of day at which to perform a scheduled scan.

The recommended state for this setting is: **1** or higher.

Note: The time value is represented as the number of minutes past midnight (00:00). For example, 120 (0x78) is equivalent to 02:00 AM. By default, this setting is set to a time value of 2:00 AM. The schedule is based on local time on the computer where the scan is executing.

Rationale:

Performing a daily quick scan is a consistent, low-impact way to verify that critical parts of the system remain clean.

Impact:

This setting is not expected to negatively impact system performance, as quick scans are designed to be lightweight.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1** or higher.

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Scan:ScheduleTime

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **1** or higher:

Defender\Schedule Scan Time

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Schedule Scan Time** to **1** or higher

Default Value:

Disabled. (A scheduled scan will run at a default time.)

References:

1. GRID: MS-00000667

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

2.45 Ensure 'Schedule Scan Day' is set to 'Enabled: 0' or higher, but not '8' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures the day of the week to perform a scheduled scan.

The recommended state for this setting is: **Enabled: 0** (Every Day) or higher, but not **8** (No Scheduled Scan).

This setting can be configured with the following values:

- (0x0) Every Day
- (0x1) Sunday
- (0x2) Monday
- (0x3) Tuesday
- (0x4) Wednesday
- (0x5) Thursday
- (0x6) Friday
- (0x7) Saturday
- (0x8) No Scheduled Scan

Rationale:

Performing a scheduled scan at least once a week is a consistent way to verify that critical parts of the system remain clean.

Impact:

If **Quick Scans** are used for the scheduled scan type, this setting is not expected to negatively affect system performance, as these scans are intentionally designed to be lightweight.

If **Full Scans** are used for the scheduled scan type, this may impact system performance as a full scan comprehensively scans every file, folder, running process, and system area on the device.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **0, 1, 2, 3, 4, 5, 6, or 7**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Scan:ScheduleDay
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Enabled: 0** or higher, but not **8**:

```
Defender\Schedule Scan Day
```

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Schedule Scan Day** to **Enabled: 0** or higher, but not **8**

Default Value:

Disabled. (A scheduled scan will run at a default frequency.)

References:

1. GRID: MS-00000664

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.46 Ensure 'Signature Update Interval' is set to '4' or fewer, but not '0' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures an interval at which to check for security intelligence updates. Security intelligence updates are the continuously updated packages that Microsoft Defender Antivirus uses to recognize, classify, and block the latest malware, spyware, unwanted software, and potentially harmful behaviors.

The recommended state for this setting is: **4** or fewer, but not **0**.

Note: The time value is represented as the number of hours between update checks. Valid values range from 1 (every hour) to 24 (once per day).

Rationale:

A malware scan is only as effective as the threat definitions it uses. Running a scan with outdated intelligence significantly reduces detection accuracy and can create a false sense of security.

Impact:

Checking for updated security intelligence can add a small amount of overhead to the system.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **4**, **3**, **2**, or **1**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Signature  
Updates:SignatureUpdateInterval
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **4** or fewer, but not **0**:

Defender\Signature Update Interval

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Signature Update Interval** to **4** or fewer, but not **0**

Default Value:

Disabled. (Checks for security intelligence updates will occur at the default interval.)

References:

1. GRID: MS-00000668

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v8	10.2 Configure Automatic Anti-Malware Signature Updates Configure automatic updates for anti-malware signature files on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.47 Ensure 'Submit Samples Consent' is set to 'Enabled: Send safe samples automatically' or higher (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures the behavior of samples sent to Microsoft for submission when opt-in for MAPS telemetry is set.

The recommended state for this setting is: **Enabled: Send safe samples automatically** or **Enabled: Send all samples automatically**.

Rationale:

For the *Block at First Sight* feature to function properly, the *Send file samples when further analysis is required* setting must be configured as prescribed.

Impact:

Submitting samples carries a small risk that sensitive information may be inadvertently included.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_DWORD** value of **1** or **3**.

HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Spynet:SubmitSamplesConsent

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Enabled: Send safe samples automatically** or **Enabled: Send all samples automatically**:

Defender\Submit Samples Consent

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Submit Samples Consent** to **Enabled: Send safe samples automatically** or **Enabled: Send all samples automatically**

Default Value:

Not configured.

References:

1. GRID: MS-00000640

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

2.48 Ensure 'Remediation action for Moderate severity threats' is set to 'Quarantine or Remove' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures which automatic remediation action Microsoft Defender Antivirus will take for each threat alert level detection.

The recommended state for this setting is: **Quarantine. Moves files to quarantine.** Configuring this setting to **Remove. Removes files from system.** also conforms to the benchmark.

Rationale:

By default, Defender uses the action embedded in each threat's malware signature (clean, quarantine, remove, etc.). Configuring this setting ensures the same action is always taken, regardless of how Microsoft classifies a specific threat.

Impact:

If tamper protection is enabled in the environment, this setting is ignored because tamper protection enforces its own default action. In this case an exception to this recommendation will be needed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_SZ** value of **2** or **3**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\Threats\ThreatSeverityDefaultAction:2
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Quarantine. Moves files to quarantine.** or **Remove. Removes files from system.**:

Defender\Remediation action for Moderate severity threats

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Remediation action for Moderate severity threats** to **Quarantine. Moves files to quarantine** or **Remove. Removes files from system.**

Default Value:

Not Configured.

References:

1. GRID: MS-00000669

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

2.49 Ensure 'Remediation action for High severity threats' is set to 'Quarantine or Remove' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures which automatic remediation action Microsoft Defender Antivirus will take for each threat alert level detection.

The recommended state for this setting is: **Quarantine. Moves files to quarantine.** Configuring this setting to **Remove. Removes files from system.** also conforms to the benchmark.

Rationale:

By default, Defender uses the action embedded in each threat's malware signature (clean, quarantine, remove, etc.). Configuring this setting ensures the same action is always taken, regardless of how Microsoft classifies a specific threat.

Impact:

If tamper protection is enabled in the environment, this setting is ignored because tamper protection enforces its own default action. In this case an exception to this recommendation will be needed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_SZ** value of **2** or **3**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\Threats\ThreatSeverityDefaultAction:4
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Quarantine. Moves files to quarantine.** or **Remove. Removes files from system.**:

Defender\Remediation action for High severity threats

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Remediation action for High severity threats** to **Quarantine. Moves files to quarantine** or **Remove. Removes files from system.**

Default Value:

Not Configured.

References:

1. GRID: MS-00000669

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

2.50 Ensure 'Remediation action for Severe threats' is set to 'Quarantine or Remove' (Automated)

Profile Applicability:

- Level 1 - Workstation

Description:

This policy setting configures which automatic remediation action Microsoft Defender Antivirus will take for each threat alert level detection.

The recommended state for this setting is: **Quarantine. Moves files to quarantine.** Configuring this setting to **Remove. Removes files from system.** also conforms to the benchmark.

Rationale:

By default, Defender uses the action embedded in each threat's malware signature (clean, quarantine, remove, etc.). Configuring this setting ensures the same action is always taken, regardless of how Microsoft classifies a specific threat.

Impact:

If tamper protection is enabled in the environment, this setting is ignored because tamper protection enforces its own default action. In this case an exception to this recommendation will be needed.

Audit:

Navigate to the UI Path articulated in the Remediation section and confirm it is set as prescribed. This policy setting is backed by the following registry location with a **REG_SZ** value of **2** or **3**.

```
HKLM\SOFTWARE\Policies\Microsoft\Windows  
Defender\Threats\ThreatSeverityDefaultAction:5
```

Remediation:

To establish the recommended configuration via configuration profiles, set the following Settings Catalog path to **Quarantine. Moves files to quarantine. or Remove. Removes files from system.:**

Defender\Remediation action for Severe threats
--

To establish the recommended configuration via Endpoint Security Blade:

1. Navigate to **Endpoint Security**
2. Click **Antivirus**
3. Click **Create Profile**
4. Select **Windows** for the **Platform** and **Microsoft Defender Antivirus** for **Profile**
5. Name the profile
6. Configure **Remediation action for Severe threats** to **Quarantine. Moves files to quarantine or Remove. Removes files from system.**

Default Value:

Not Configured.

References:

1. GRID: MS-00000669

Additional Information:

- Microsoft Defender Antivirus (Built-in, baseline protection)
- Microsoft Defender for Endpoint Plan 1, (Foundational enterprise endpoint protection)
- Microsoft Defender for Endpoint Plan 2, (Full enterprise EDR + XDR tier)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	Microsoft Defender Antivirus		
1.1	Client Interface		
1.2	Exclusions		
1.3	MAPS		
1.3.1	Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled' (Automated)	☐	☐
1.3.2	Ensure 'Configure the 'Block at First Sight' feature' is set to 'Enabled' (Automated)	☐	☐
1.4	Microsoft Defender Exploit Guard		
1.5	MpEngine		
1.6	Network Inspection System		
1.7	Quarantine		
1.8	Real-time Protection		
1.8.1	Ensure 'Turn on process scanning whenever real-time protection is enabled' is set to 'Enabled' (Automated)	☐	☐
1.9	Remediation		
1.10	Reporting		
1.10.1	Ensure 'Configure Watson events' is set to 'Disabled' (Automated)	☐	☐
1.11	Scan		
1.12	Security Intelligence Updates		
1.13	Threats		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.14	Ensure 'Turn off routine remediation' is set to 'Disabled' (Automated)	☐	☐
2	Defender		
2.1	Ensure 'Allow Archive Scanning' is set to 'Allowed' (Automated)	☐	☐
2.2	Ensure 'Allow Behavior Monitoring' is set to 'Allowed' (Automated)	☐	☐
2.3	Ensure 'Allow Cloud Protection' is set to 'Allowed' (Automated)	☐	☐
2.4	Ensure 'Allow Email Scanning' is set to 'Allowed' (Automated)	☐	☐
2.5	Ensure 'Allow Full Scan Removable Drive Scanning' is set to 'Allowed' (Automated)	☐	☐
2.6	Ensure 'Allow On Access Protection' is set to 'Allow' (Automated)	☐	☐
2.7	Ensure 'Allow Realtime Monitoring' is set to 'Allowed' (Automated)	☐	☐
2.8	Ensure 'Allow scanning of all downloaded files and attachments' is set to 'Allowed' (Automated)	☐	☐
2.9	Ensure 'Allow Script Scanning' is set to 'Allowed' (Automated)	☐	☐
2.10	Ensure 'ASR: Block abuse of exploited vulnerable signed drivers' is set to 'Block' (Automated)	☐	☐
2.11	Ensure 'ASR: Block Adobe Reader from creating child processes' is set to 'Block' (Automated)	☐	☐
2.12	Ensure 'ASR: Block all Office applications from creating child processes' is set to 'Audit' or higher (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.13	Ensure 'ASR: Block credential stealing from the Windows local security authority subsystem' is set to 'Block' (Automated)	☐	☐
2.14	Ensure 'ASR: Block executable content from email client and webmail' is set to 'Block' (Automated)	☐	☐
2.15	Ensure 'ASR: Block executable files from running unless they meet a prevalence, age, or trusted list criterion' is set to 'Audit' or higher (Automated)	☐	☐
2.16	Ensure 'ASR: Block execution of potentially obfuscated scripts' is set to 'Audit' or higher (Automated)	☐	☐
2.17	Ensure 'ASR: Block JavaScript or VBScript from launching downloaded executable content' is set to 'Block' (Automated)	☐	☐
2.18	Ensure 'ASR: Block Office applications from creating executable content' is set to 'Block' (Automated)	☐	☐
2.19	Ensure 'ASR: Block Office applications from injecting code into other processes' is set to 'Block' (Automated)	☐	☐
2.20	Ensure 'ASR: Block Office communication application from creating child processes' is set to 'Audit' or higher (Automated)	☐	☐
2.21	Ensure 'ASR: Block persistence through WMI event subscription' is set to 'Block' (Automated)	☐	☐
2.22	Ensure 'ASR: Block process creations originating from PSEXEC and WMI commands' is set to 'Audit' or higher (Automated)	☐	☐
2.23	Ensure 'ASR: Block rebooting machine in Safe Mode' is set to 'Block' (Automated)	☐	☐
2.24	Ensure 'ASR: Block untrusted and unsigned processes that run from USB' is set to 'Block' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.25	Ensure 'ASR: Block Win32 API calls from Office macros' is set to 'Block' (Automated)	☐	☐
2.26	Ensure 'ASR: Use advanced protection against ransomware' is set to 'Audit' or higher (Automated)	☐	☐
2.27	Ensure 'Check For Signatures Before Running Scan' is set to 'Enabled' (Automated)	☐	☐
2.28	Ensure 'Cloud Block Level' is set to Enabled: High blocking level' or higher (Automated)	☐	☐
2.29	Ensure 'Cloud Extended Timeout' is set to '1 or higher, but not 0' (Automated)	☐	☐
2.30	Ensure 'Days Until Aggressive Catchup Quick Scan' is set to '7' days (Automated)	☐	☐
2.31	Ensure 'Enable Convert Warn To Block' is set to 'Warn verdicts are converted to block' (Automated)	☐	☐
2.32	Ensure 'Enable Dynamic Signature Dropped Event Reporting' is set to 'Dynamic Security intelligence update events will be reported.' (Automated)	☐	☐
2.33	Ensure 'Enable File Hash Computation' is set to 'Enable' (Automated)	☐	☐
2.34	Ensure 'Enable Network Protection' is set to 'Enabled (block mode)' (Automated)	☐	☐
2.35	Ensure 'Hide Exclusions From Local Users' is set to 'Enabled' (Automated)	☐	☐
2.36	Ensure 'Oobe Enable Rtp And Sig Update' is set to 'Enabled' (Automated)	☐	☐
2.37	Ensure 'PUA Protection' is set to 'PUA Protection on' (Automated)	☐	☐
2.38	Ensure 'Quick Scan Include Exclusions' is set to '1' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.39	Ensure 'Real Time Scan Direction' is set to 'Monitor all files bi-directional' (Automated)	☐	☐
2.40	Ensure 'Remote Encryption Protection Aggressiveness' is set to 'Medium' or higher (Automated)	☐	☐
2.41	Ensure 'Remote Encryption Protection Configured State' is set to 'Audit: Generate EDR detections without blocking' or higher (Automated)	☐	☐
2.42	Ensure 'Scan Parameter' is set to 'Quick Scan' or higher (Automated)	☐	☐
2.43	Ensure 'Schedule Quick Scan Time' is set to '1' or higher (Automated)	☐	☐
2.44	Ensure 'Schedule Scan Time' is set to '1' or higher (Automated)	☐	☐
2.45	Ensure 'Schedule Scan Day' is set to 'Enabled: 0' or higher, but not '8' (Automated)	☐	☐
2.46	Ensure 'Signature Update Interval' is set to '4' or fewer, but not '0' (Automated)	☐	☐
2.47	Ensure 'Submit Samples Consent' is set to 'Enabled: Send safe samples automatically' or higher (Automated)	☐	☐
2.48	Ensure 'Remediation action for Moderate severity threats' is set to 'Quarantine or Remove' (Automated)	☐	☐
2.49	Ensure 'Remediation action for High severity threats' is set to 'Quarantine or Remove' (Automated)	☐	☐
2.50	Ensure 'Remediation action for Severe threats' is set to 'Quarantine or Remove' (Automated)	☐	☐

Appendix: Change History

Date: 05/27/2026 Version: 1.0.0
Initial Public Release